SOC Nivel 1 para ConectaValle Telecom S.A.S. (Caso C11)

Camilo Andrés Pérez Carvajal

Sebastián Salón Quintero

Universidad Tecnológica de Santander

Ingeniería de Sistemas Informáticos

Ética del Hacking

Docente: Julian Barney Jaimes Rincón

Bucaramanga-Santander Colombia

21 de octubre de 2026

Informe técnico: SOC Nivel 1 para ConectaValle Telecom S.A.S. (Caso C11)

Parcial segundo corte · Ética del Hacking / Ciberseguridad Defensiva · Docente: Julian Barney Jaimes Rincón · Autores: Camilo Andrés Pérez Carvajal y Sebastián Salón Quintero · Fecha: 21 de octubre de 2026

Control de versiones

Versión	Fecha	Cambio	Autor
0.1	[fecha]	Borrador base del caso C11	C. Pérez; S. Salón
0.2	[fecha]	Evidencias de Fases 0 a 3 (Punto de control 1)	C. Pérez; S. Salón
1.0	[fecha]	Entrega final	C. Pérez; S. Salón

1. Resumen ejecutivo

ConectaValle Telecom S.A.S. es un proveedor de Internet (ISP) pequeño, con 10 empleados y 20 equipos de cómputo, que opera un NOC con guardias y expone a Internet su portal de clientes y su plataforma de facturación. Sus activos críticos son RADIUS, el DNS recursivo, el DHCP, la facturación y los routers de borde. Hoy no tiene SIEM, EDR centralizado ni mesa de tickets de seguridad.

Se diseñó e implementó, en un laboratorio aislado, un SOC N1 con Wazuh como SIEM, Kaspersky como EDR/XDR y GLPI en la nube como mesa de servicio e inventario. El NGFW se cotizó con tres proveedores, sin instalarlo. Se definieron severidades, triage, nueve playbooks, turnos, SLA y KPIs, y se gestionaron [6] tickets, de los cuales [4] vinieron de alertas reales del laboratorio.

Resultados: [cobertura de agentes en el laboratorio: X de Y]; [N reglas personalizadas probadas con wazuh-logtest]; [N alertas reales generadas para los 3 escenarios del caso]; [MTTA medido: X min].

Costo: CAPEX de COP [valor] frente al tope de COP 70 M; OPEX de COP [valor] por mes frente al tope de COP 5 M por mes; TCO a 3 años de COP [valor]. TRM usada: [valor] al [fecha].

2. Caso y alcance

> ***Nota de uso de IA:*** *la redacción base de este capítulo (supuestos, alcance, clasificación de la información, marco legal, inventario y matriz de riesgos) se elaboró con ayuda de inteligencia artificial; se declara en el Anexo I.*

2.1 Resumen del caso

[Reescribe con tus palabras]. ConectaValle presta acceso a Internet a abonados mediante OLT y antenas (fuera de los 20 equipos), con dos salidas BGP hacia proveedores upstream, un switch core de 24 puertos y tres VLAN sugeridas: Gestión fuera de banda, Servicios (DNS y RADIUS) y Oficina. Maneja datos personales de abonados y registros de conexión, por lo que le aplica la Ley 1581 de 2012 y las obligaciones de MinTIC y la CRC, incluida la conservación de registros (verificar la normativa vigente). El riesgo particular es el DDoS y el abuso de DNS, el compromiso de RADIUS y los abonados que escanean o atacan la red del proveedor.

2.2 Supuestos declarados

1. El reparto de los 9 servidores Linux es un supuesto mío: 2 RADIUS, 2 DNS, 1 DHCP, 1 monitoreo, 1 base de datos de facturación, 1 portal de clientes y 1 respaldo.
2. Los servidores del SOC (Wazuh, consola Kaspersky) y la VM de GLPI en la nube son infraestructura de seguridad adicional y no se cuentan entre los 20 equipos productivos. [Confirmar con el docente: la guía indica que un VPS administrado por la empresa se cuenta dentro de los 20.]
3. Los equipos de red (routers de borde, switch core, OLT, antenas) se cuentan aparte, como indica la guía.
4. Todos los datos, nombres, dominios e IP son ficticios. El dominio de ejemplo es conectavalle.example y las IP son privadas de ejemplo.
5. Zona horaria única America/Bogota con NTP en todos los equipos.
6. El monitoreo es presencial en horario laboral y por guardia fuera de él, apoyado en las guardias de NOC que la empresa ya tiene.

2.3 Alcance del SOC N1

Aspecto	Definición
Incluido	Los 20 equipos productivos, los servicios expuestos (portal y facturación), los respaldos en almacenamiento externo, la red de gestión y el NGFW (logs).
Excluido	Equipos de los abonados, OLT y antenas (solo su gestión por VLAN 99), mitigación volumétrica de DDoS en el upstream, forense (N2/N3), cualquier sistema fuera del laboratorio.
Horario	Lunes a viernes 7:00 a 19:00 con dos analistas traslapados; noches, fines de semana y festivos por guardia (ver capítulo 8).
Actividades permitidas	Instalar y configurar herramientas en VM propias; generar eventos de prueba controlados (EICAR, cambio en archivos vigilados, intentos fallidos de autenticación y tráfico bloqueado entre VM propias).
Actividades prohibidas	Escaneos o pruebas contra sistemas fuera del laboratorio, uso de datos reales, captura de tráfico ajeno, desactivar controles de terceros.
Metas iniciales	Cobertura de agentes ≥ 98 %, 3 escenarios del caso detectados y con ticket, 90 % de tickets dentro del SLA.

2.4 Clasificación de la información

Nivel	Ejemplos en ConectaValle	Tratamiento
Pública	Planes comerciales, logo	Sin restricción
Interna	Procedimientos del NOC, playbooks	Solo personal
Confidencial	Datos de abonados, facturación, logs de conexión	Acceso por rol, cifrado en tránsito
Restringida	Secretos RADIUS, llaves rndc, credenciales de routers, contraseñas del SOC	Gestor de contraseñas, nunca en tickets, repositorio ni capturas

Los logs, tickets y evidencias del SOC se tratan como Confidenciales. Los tickets no deben contener datos personales de abonados: se referencia el identificador de contrato, no el nombre ni la cédula.

2.5 Marco legal y de referencia

Norma o estándar	Cómo se aplica en este caso
Ley 1273 de 2009	Delitos informáticos: por eso toda prueba tiene autorización escrita y se hace solo en VM propias.
Ley 1581 de 2012	Protección de datos personales de abonados: mínimo necesario en logs y tickets, control de acceso y respaldos protegidos.
MinTIC y CRC	Obligaciones de proveedores de redes y servicios, incluida la conservación de registros. [Verificar la normativa vigente y el plazo exigido; ajustar la retención de la sección 3.7.]
ISO/IEC 27001:2022	Controles de referencia: A.5.9 inventario, A.5.24 a A.5.28 gestión de incidentes, A.7.10 medios de almacenamiento, A.8.7 malware, A.8.8 vulnerabilidades, A.8.13 respaldos, A.8.15 y A.8.16 registro y monitoreo, A.8.20 y A.8.22 seguridad y segregación de red.
NIST CSF 2.0	Gobernar (RACI y políticas), Identificar (inventario y riesgos), Proteger (políticas Kaspersky, NGFW), Detectar (Wazuh), Responder (playbooks y SLA), Recuperar (respaldos y restauración).

2.6 Inventario de activos (Anexo A)

W = agente Wazuh · K = agente Kaspersky · G = GLPI Agent. C/I/D de 1 a 3; Crit. es el máximo. Los hostnames llevan el marcador de caso C11. En el laboratorio, usa además tus iniciales (por ejemplo, SRV-C11-DNS01-<INI>).

ID	Hostname	Tipo	SO	Función	Propietario	VLAN	IP ejemplo	C/I/D	Crit.	W/K/G
A-01 a A-05	PC-C11-01 a 05	Estación	Windows 11	Atención al cliente	Jefe de atención	10	10.10.10.11 a 15	3/2/2	3	Sí/Sí/Sí
A-06 a A-08	NB-C11-01 a 03	Portátil	Windows 11	NOC e instalaciones	Líder NOC	10	10.10.10.21 a 23	3/3/2	3	Sí/Sí/Sí
A-09	MAC-C11-01	Portátil	macOS	Gerencia	Gerente	10	10.10.10.31	3/2/2	3	Sí/Verificar/Sí

A-10	SRV-C11-RAD01	Servidor	Linux	RADIUS primario	Admin. de TI	20	10.10.20.11	3/3/3	3	Sí/Verificar/Sí
A-11	SRV-C11-RAD02	Servidor	Linux	RADIUS secundario	Admin. de TI	20	10.10.20.12	3/3/3	3	Sí/Verificar/Sí
A-12	SRV-C11-DNS01	Servidor	Linux	DNS recursivo y autoritativo	Admin. de TI	20	10.10.20.21	2/3/3	3	Sí/Verificar/Sí
A-13	SRV-C11-DNS02	Servidor	Linux	DNS secundario	Admin. de TI	20	10.10.20.22	2/3/3	3	Sí/Verificar/Sí
A-14	SRV-C11-DHCP01	Servidor	Linux	DHCP	Admin. de TI	20	10.10.20.31	2/2/3	3	Sí/Verificar/Sí
A-15	SRV-C11-MON01	Servidor	Linux	Monitoreo de red (NMS)	Líder NOC	20	10.10.20.41	3/2/2	3	Sí/Verificar/Sí
A-16	SRV-C11-FAC01	Servidor	Linux	Base de datos de facturación	Jefe de facturación	25	10.10.25.11	3/3/3	3	Sí/Verificar/Sí
A-17	SRV-C11-WEB01	Servidor	Linux	Portal de clientes (expuesto)	Admin. de TI	25	10.10.25.21	3/3/3	3	Sí/Verificar/Sí
A-18	SRV-C11-BCK01	Servidor	Linux	Respaldos (con copia externa)	Admin. de TI	50	10.10.50.11	3/3/2	3	Sí/Verificar/Sí
A-19	SRV-C11-AD01	Servidor	Windows Server 2022	Active Directory	Admin. de TI	20	10.10.20.51	3/3/3	3	Sí/Sí/Sí
A-20	SRV-C11-FAC02	Servidor	Windows Server 2022	Aplicación de facturación	Jefe de facturación	25	10.10.25.12	3/3/3	3	Sí/Sí/Sí

Infraestructura del SOC (fuera de los 20, ver supuesto 2): wazuh-c11-<INI> (10.10.90.10), ksc-c11-<INI> (10.10.90.11) y GLPI en la nube (glpi-c11-<INI>). Equipos de red: 2 routers de borde con BGP, switch core de 24 puertos, OLT y antenas, y el futuro NGFW. Servicios en la nube: almacenamiento externo de respaldos y la VM de GLPI.

2.7 Matriz de riesgos (Anexo B)

Escalas de 1 a 5. Nivel = P × I: 1 a 4 Bajo, 5 a 9 Medio, 10 a 16 Alto, 17 a 25 Crítico.

ID	Riesgo	Activo	P	I	Nivel	Control del SOC	Fase
R-01	Fuerza bruta contra RADIUS o SSH	RAD01, RAD02, servidores Linux	4	4	16 Alto	Reglas 100311 y 100312, active response sobre la regla 5763, PB-01	2
R-02	Cambio no autorizado en zonas DNS o secuestro de DNS	DNS01, DNS02	3	5	15 Alto	FIM sobre /etc/bind, reglas 100320 y 100322, PB-03	2
R-03	DDoS o abuso de DNS (amplificación, resolver abierto)	DNS01, DNS02, WEB01, routers de borde	4	5	20 Crítico	Monitoreo de volumen y logs, NGFW, escalamiento a N2 y al upstream. La mitigación volumétrica real es del proveedor upstream.	1, 5, 6
R-04	Abonado que escanea o ataca la red de gestión	VLAN 20 y 99	4	4	16 Alto	Segmentación, regla 100301, NGFW, PB-07	1, 2, 5
R-05	Fuga de datos personales de abonados	FAC01, FAC02, WEB01, BCK01	3	5	15 Alto	FIM, control de USB, EDR, acceso por rol, PB-05	2, 3
R-06	Ransomware en facturación o estaciones	FAC02, PC-C11-xx	3	5	15 Alto	Kaspersky con respuesta, respaldo externo, PB-02	3
R-07	Explotación del portal de clientes expuesto	WEB01	4	4	16 Alto	Detección de vulnerabilidades, FIM en /var/www, IPS del NGFW, PB-09	2, 5
R-08	Cuenta privilegiada nueva o AD comprometido	AD01	3	5	15 Alto	Eventos de cambio de grupos, PB-08	2
R-09	Respaldos ausentes, comprometidos o no restaurables	BCK01	3	4	12 Alto	FIM, monitoreo, prueba de restauración	2, 4
R-10	Incumplir la conservación de registros de conexión	Logs de red	3	4	12 Alto	Retención 90 días en caliente y 12 meses archivados; verificar el plazo normativo	1
R-11	Alertas sin atender por falta de proceso o turnos	SOC	3	4	12 Alto	Playbooks, SLA, turnos y guardias	6

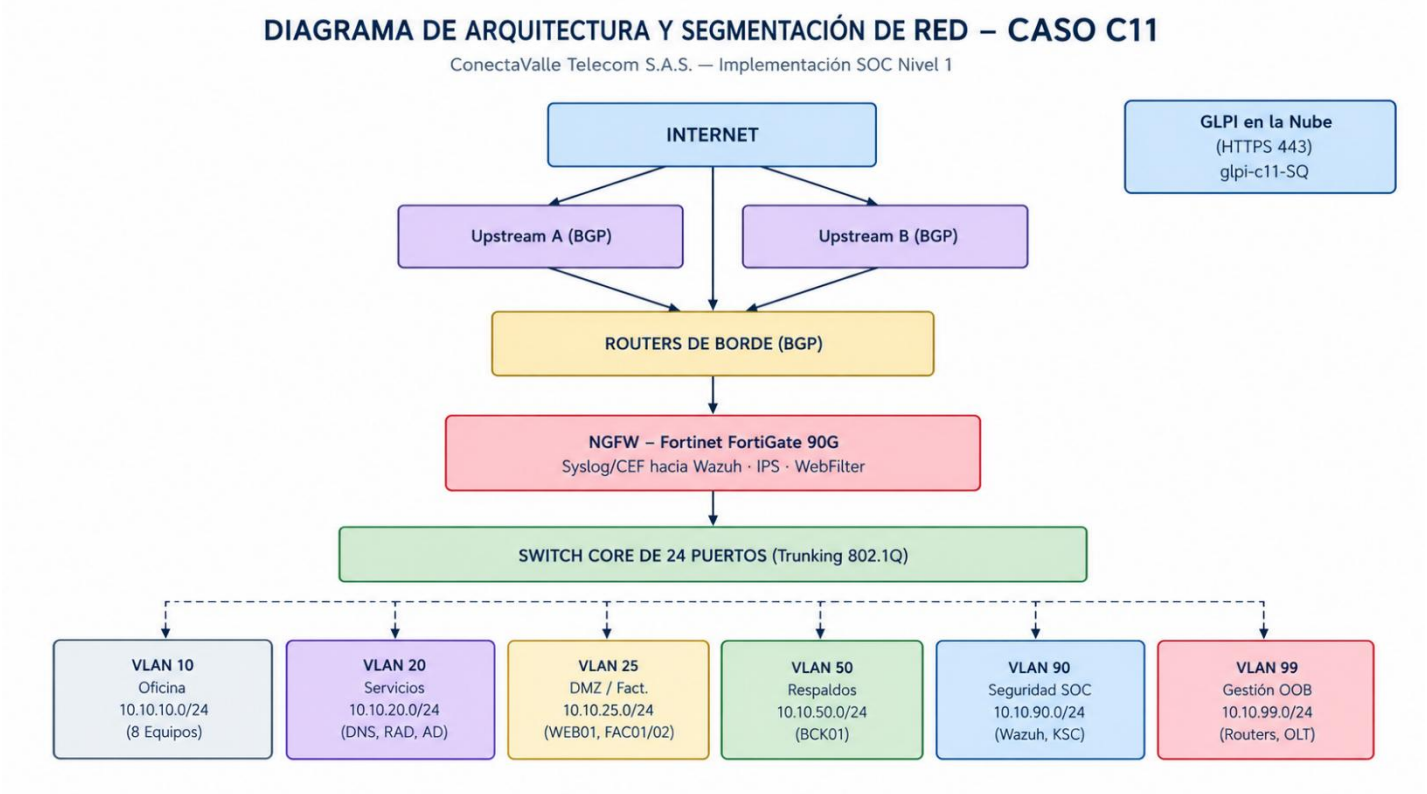
R-12	Phishing al personal de atención al cliente	PC-C11-01 a 05	4	3	12 Alto	PB-06, control web de Kaspersky	3, 6
R-13	Falta de visibilidad del inventario	20 equipos	4	3	12 Alto	GLPI Agent y agentes de Wazuh	2, 4
R-14	Equipo macOS sin cobertura de agentes	MAC-C11-01	3	2	6 Medio	Verificar compatibilidad de Wazuh y Kaspersky y documentar el procedimiento	2, 3

3. Arquitectura

> ***Nota de uso de IA:*** *la estructura y el texto de este capítulo (segmentación, flujo de logs, dimensionamiento, retención y laboratorio) se elaboraron con ayuda de inteligencia artificial; se declara en el Anexo I.*

3.1 Diagrama lógico

El diagrama final se dibuja en diagrams.net y se adjunta como archivo editable y PNG. Esta es la topología que debe representar:



3.2 Segmentación y direccionamiento

VLAN	Uso	Subred de ejemplo	Regla mínima
10	Oficina: estaciones y portátiles	10.10.10.0/24	Salida a Internet filtrada; a servidores solo por los puertos necesarios
20	Servicios: DNS, RADIUS, DHCP, AD, monitoreo	10.10.20.0/24	Administración solo desde la VLAN 99 o un bastión; DNS y RADIUS atienden solo a la red de acceso y a los NAS autorizados
25	DMZ y facturación: portal y plataforma de facturación	10.10.25.0/24	Portal publicado por el NGFW; la base de datos no es accesible desde Internet
50	Respaldos	10.10.50.0/24	Solo recibe desde los servidores y envía al almacenamiento externo por canal cifrado
90	Seguridad: Wazuh y consola Kaspersky	10.10.90.0/24	Recibe eventos de agentes y NGFW; acceso solo de analistas
99	Gestión de red fuera de banda	10.10.99.0/24	Solo administradores de red; sin salida a Internet
Abonados	Red de acceso (fuera de los 20)	172.16.0.0/16 de ejemplo	Sin ruta hacia las VLAN 20 (salvo DNS y RADIUS por puertos exactos), 90 y 99

Esta separación responde a la particularidad del caso: la red de gestión va aislada y los servicios críticos (DNS y RADIUS) tienen reglas propias. Una regla clave: un abonado nunca debería alcanzar la VLAN 99. Si el SOC ve tráfico denegado de un abonado hacia ella, es el escenario 1.

3.3 Flujo de logs

Origen	Destino	Puerto y protocolo	Qué se recolecta
Agentes Wazuh (todos los equipos)	wazuh-c11	1514/TCP	Eventos, FIM, SCA, inventario de software
Agentes Wazuh (alta)	wazuh-c11	1515/TCP	Registro de agentes
Analista N1	Dashboard de Wazuh	443/TCP	Consola
NGFW	wazuh-c11	514/UDP o TCP	Tráfico denegado, IPS, VPN, cambios de configuración
Kaspersky Security Center	wazuh-c11	514/UDP en formato CEF	Detecciones y eventos críticos
Network Agent	ksc-c11	13000/TCP y 14000/TCP	Gestión de agentes (verificar en la documentación)
Analista N1	ksc-c11	13291/TCP o 443	Consola (verificar)
Endpoints	GLPI en la nube	443/TCP	Inventario con GLPI Agent
Analista N1	GLPI en la nube	443/TCP	Tickets
GLPI	Servidor SMTP	587/TCP	Notificaciones
Todos	Servidor NTP	123/UDP	Hora única America/Bogota

Logs específicos del ISP que se recolectan: autenticación de FreeRADIUS, archivos de zona de BIND (FIM), tráfico denegado en servidores (UFW) y eventos del portal. Los logs de consultas DNS completos no se ingieren al SIEM por volumen y privacidad: se evalúa solo un muestreo o agregados.

3.4 Dimensionamiento para 20 agentes

Componente	Valor	Justificación
Wazuh todo en uno	4 vCPU, 8 GiB de RAM, 100 GB	La guía oficial da 4 vCPU, 8 GiB y 50 GB para 1 a 25 agentes con 90 días de alertas. 20 agentes más 25 a 30 % de crecimiento da 25 y cubre el rango. Se duplica el disco a 100 GB por los logs del NGFW y de RADIUS.
Kaspersky Security Center	[Según requisitos del fabricante, versión vigente]	Considerar base de datos, paquetes e instalación y actualizaciones
GLPI en la nube	2 vCPU, 4 GB de RAM, 40 GB SSD	Referencia práctica para 10 usuarios y 20 equipos con inventario y base de conocimiento
Respaldos	Copia diaria de configuración de Wazuh y GLPI	Prueba de restauración al menos una vez

3.5 Servicios transversales

NTP en todos los equipos y zona horaria America/Bogota, nomenclatura de hosts `TIPO-C11-FUNCION##`, retención de logs de 90 días en el SIEM y 12 meses archivados, y respaldos diarios con retención de [N] días.

3.6 Decisión de arquitectura

Se elige Wazuh **todo en uno**. Para 20 a 25 agentes cumple los requisitos de la guía oficial. La arquitectura distribuida se justificaría por alta disponibilidad o por un volumen mucho mayor, por ejemplo si se ingieren todos los logs de consultas DNS. Esa decisión se revisa si la empresa crece. Riesgo asumido: un solo servidor es un punto único de falla, mitigado con respaldo diario y snapshot.

3.7 Política de retención

90 días en el índice del SIEM para búsquedas rápidas y 12 meses archivados. **El plazo definitivo depende de la normativa de MinTIC y la CRC vigente para registros de conexión.** [Verificar y justificar el valor final con la fuente oficial.]

3.8 Laboratorio mínimo y plan de despliegue masivo

VM	Rol	Recursos	Red
wazuh-c11-<INI>	Wazuh todo en uno (Ubuntu Server LTS)	4 vCPU, 8 GB, 50 a 100 GB	Host-only, 10.10.90.10
ksc-c11-<INI>	Consola Kaspersky (Windows Server)	Según fabricante	10.10.90.11
win11-c11-<INI>	Endpoint Windows con agentes Wazuh y Kaspersky	2 vCPU, 4 GB	10.10.10.11
lnx-svc-c11-<INI>	Linux que simula DNS (BIND9) y RADIUS (FreeRADIUS) con SSH	2 vCPU, 2 GB	10.10.20.21
lnx-atk-c11-<INI>	Linux de pruebas para generar tráfico y fallos contra mis propias VM	1 vCPU, 1 GB	10.10.10.99

glpi-c11-<INI>	GLPI en un VPS con HTTPS	2 vCPU, 4 GB, 40 GB	Nube

Plan de despliegue para los 20 equipos: Windows por directiva de grupo o script desde AD01 (estaciones, portátiles y servidores Windows), Linux por script con Ansible o SSH usando el repositorio de Wazuh, macOS con el paquete .pkg y verificación en la documentación oficial. Portátiles remotos: instalación manual al regresar a la oficina o por VPN. [Describe tu orden de despliegue: primero servidores críticos, luego estaciones.]

4. SIEM Wazuh

> ***Nota de uso de IA:*** *los borradores de comandos, reglas, decoders y la redacción de este capítulo se elaboraron con ayuda de inteligencia artificial; se declara en el Anexo I.*

Versión usada: [Wazuh 4.14.x, confirmar con `wazuh-control info`]. Los agentes no deben tener una versión mayor que la del manager. Los comandos siguen la guía oficial; verifica la versión vigente antes de ejecutarlos.

4.1 Instalación del servidor

```
sudo hostnamectl set-hostname wazuh-c11-<INI>
sudo timedatectl set-timezone America/Bogota && sudo timedatectl set-ntp true
sudo apt update && sudo apt -y upgrade && sudo apt -y install curl tar unzip
curl -sO https://packages.wazuh.com/4.14/wazuh-install.sh && sudo bash ./wazuh-
install.sh -a
sudo systemctl status wazuh-indexer wazuh-manager wazuh-dashboard --no-pager
```

La contraseña de admin se guarda en un gestor de contraseñas y **nunca** aparece en capturas, informe ni repositorio. Firewall del servidor (UFW), limitado a las redes del caso:

```
sudo ufw allow from <IP_ADMIN> to any port 22 proto tcp
sudo ufw allow from 10.10.10.0/24 to any port 1514,1515 proto tcp
sudo ufw allow from 10.10.20.0/24 to any port 1514,1515 proto tcp
sudo ufw allow from 10.10.25.0/24 to any port 1514,1515 proto tcp
sudo ufw allow from 10.10.50.0/24 to any port 1514,1515 proto tcp
sudo ufw allow from 10.10.90.0/24 to any port 443 proto tcp
sudo ufw allow from 10.10.90.11 to any port 514 proto udp   # Kaspersky (CEF)
sudo ufw allow from 10.10.99.0/24 to any port 514 proto udp # NGFW (syslog)
sudo ufw enable
```

4.2 Grupos de agentes y despliegue

Se crean grupos por función del activo, porque cada servicio crítico del ISP necesita una vigilancia distinta. Un agente puede pertenecer a varios grupos y la configuración se combina.

Grupo	Equipos	Para qué
linux-servidores	Los 9 Linux	FIM base, log de UFW
linux-dns	DNS01, DNS02	FIM de /etc/bind (escenario 3)
linux-radius	RAD01, RAD02	Log de FreeRADIUS y FIM de /etc/freeradius (escenario 2)
linux-web	WEB01	FIM de /var/www
windows-estaciones	5 estaciones y 3 portátiles	FIM de rutas públicas y claves Run
windows-servidores	AD01, FAC02	FIM de archivo hosts y registro; eventos de AD

macos-portatiles	MAC-C11-01	Cobertura básica de gerencia

```
for g in linux-servidores linux-dns linux-radius linux-web windows-estaciones
windows-servidores macos-portatiles; do
  sudo /var/ossec/bin/agent_groups -a -g $g -q
done
```

Agente Linux (Debian y Ubuntu), con el grupo correspondiente:

```
curl -s https://packages.wazuh.com/key/GPG-KEY-WAZUH | sudo gpg --no-default-
keyring --keyring gnupg-ring:/usr/share/keyrings/wazuh.gpg --import && sudo
chmod 644 /usr/share/keyrings/wazuh.gpg
echo "deb [signed-by=/usr/share/keyrings/wazuh.gpg]
https://packages.wazuh.com/4.x/apt/ stable main" | sudo tee
/etc/apt/sources.list.d/wazuh.list
sudo apt update
sudo WAZUH_MANAGER='10.10.90.10' WAZUH_AGENT_GROUP='linux-servidores,linux-dns'
WAZUH_AGENT_NAME='SRV-C11-DNS01-<INI>' apt -y install wazuh-agent
sudo systemctl daemon-reload && sudo systemctl enable --now wazuh-agent
```

Agente Windows (PowerShell como administrador). Usa el comando que genera el Dashboard para tu versión:

```
msiexec.exe /i $env:tmp\wazuh-agent.msi /q WAZUH_MANAGER='10.10.90.10'
WAZUH_AGENT_GROUP='windows-estaciones' WAZUH_AGENT_NAME='PC-C11-01-<INI>'
NET START WazuhSvc
```

macOS: el agente existe como paquete .pkg, pero [verificar en la documentación oficial la compatibilidad con tu versión de macOS y la edición elegida y documentar el procedimiento]. Si no tienes hardware Apple, documenta el procedimiento sin ejecutarlo y díselo al docente.

4.3 Monitoreo de integridad de archivos (FIM)

Los archivos completos están en el repositorio, carpeta `02-wazuh/shared/`. La parte clave para el caso es el DNS: cualquier cambio en las zonas o en `named.conf` debe tener un ticket de cambio.

```
<!-- /var/ossec/etc/shared/linux-dns/agent.conf -->
<agent_config os="Linux">
  <syscheck>
    <directories check_all="yes" realtime="yes"
report_changes="yes">/etc/bind</directories>
    <nodiff>/etc/bind/rndc.key</nodiff>
  </syscheck>
</agent_config>
```

La etiqueta `nodiff` evita que Wazuh guarde el contenido de llaves y secretos en el diff. Se aplica igual al archivo `clients.conf` y al archivo `authorize` de FreeRADIUS.

4.4 Evaluación de configuración (SCA) y vulnerabilidades

SCA viene habilitado por defecto con las políticas CIS que correspondan al sistema operativo de cada agente. [Adjunta captura del puntaje de SCA de un servidor Linux y del endpoint Windows y explica 2 controles fallidos y su remediación.] La detección de vulnerabilidades se configura en el manager (`<vulnerability-detection>`); [verifica en tu versión que esté en `yes` y que el feed se actualiza]. Adjunta captura de CVE reales detectados en un agente. Estos hallazgos alimentan el playbook PB-09.

4.5 Reglas y decoders personalizados

Se crearon 11 reglas, más de las 3 mínimas, relacionadas con los tres escenarios del caso. Todas se probaron con `wazuh-logtest` antes de reiniciar el manager. Los archivos completos están en `02-wazuh/` del repositorio.

ID	Nivel	Escenario	Lógica
100300	3	1. Escaneo de puertos	Tráfico bloqueado por UFW, decodificado con origen, destino y puerto
100301	8	1. Escaneo de puertos	15 bloqueos desde la misma IP en 30 s
100302	10	1. Escaneo de puertos	El escaneo apunta a las VLAN 20 o 99 (servidores de gestión)
100310	5	2. Fuerza bruta RADIUS	Fallo de autenticación en FreeRADIUS
100311	10	2. Fuerza bruta RADIUS	5 fallos del mismo usuario en 120 s
100312	8	2. Fuerza bruta RADIUS	15 fallos desde el mismo NAS en 60 s (password spraying)
100314	3	2. Fuerza bruta RADIUS	Login correcto, para verificar si hubo acceso tras los fallos
100320	12	3. Cambio en DNS	Cambio en `/etc/bind` (zonas o `named.conf`)
100322	14	3. Cambio en DNS	El mismo cambio fuera de 6 am a 7 pm
100200	5	EDR	Evento de Kaspersky en formato CEF
100201	10	EDR	Evento de Kaspersky con severidad 7 a 10

Para SSH se reutilizan las reglas incluidas de Wazuh (la 5763 detecta fuerza bruta en `sshd`; verifica el ID en tu ruleset).

```
<!-- local_decoder.xml (fragmento) -->
<decoder name="ufw-block-c11">
  <prematch type="pcre2">\[UFW BLOCK\]</prematch>
</decoder>
<decoder name="ufw-block-c11-campos">
  <parent>ufw-block-c11</parent>
  <regex type="pcre2">SRC=(\S+) DST=(\S+) .*?PROTO=(\w+) SPT=(\d+)
DPT=(\d+)</regex>
  <order>srcip,dstip,protocol,srcport,dstport</order>
</decoder>
<decoder name="freeradius-c11">
  <prematch type="pcre2">: Auth: \(\d+\) Login (?:incorrect|OK)</prematch>
</decoder>
<decoder name="freeradius-c11-campos">
  <parent>freeradius-c11</parent>
  <regex type="pcre2">Auth: \((\d+)\) Login (\w+).*?: \[([^/\]]+)/.*?\] \(from
client (\S+) port</regex>
  <order>request_id,action,dstuser,nas</order>
</decoder>
```

```
<!-- local_rules.xml (escenario 3) -->
<rule id="100320" level="12">
  <if_sid>550,553,554</if_sid>
  <field name="file" type="pcre2">^/etc/bind/(db\.|named\.conf|zones/)</field>
  <description>DNS: cambio en configuracion o zonas ($(file)); verificar ticket
de cambio</description>
  <group>syscheck,dns,</group>
</rule>
```

Para validar, pega esta línea en `wazuh-logtest` y revisa que la fase 2 muestre tu decoder:

```
Oct 18 10:15:01 lnx-svc-c11 kernel: [12345.678901] [UFW BLOCK] IN=ens33 OUT=
MAC=00:00:00:00:00:00:00:00:00:00:00:00:08:00 SRC=10.10.10.99 DST=10.10.20.21
LEN=44 TOS=0x00 PREC=0x00 TTL=58 ID=1234 PROTO=TCP SPT=44321 DPT=22 WINDOW=1024
RES=0x00 SYN URGP=0
Sun Oct 18 10:20:01 2026 : Auth: (12) Login incorrect: [usuario_lab/<via Auth-
Type = PAP>] (from client nas-olt01 port 0)
```

[Si en tu `wazuh-logtest` aparece otro decoder (por ejemplo `kernel` o `iptables`) antes que el mío, ajusta la relación padre-hijo y documenta el cambio. Pega la captura de la salida final.]

4.6 Respuesta activa

```
<!-- ossec.conf del manager -->
<global>
  <white_list>10.10.90.0/24</white_list>
  <white_list>10.10.99.0/24</white_list>
</global>
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>5763</rules_id>
  <timeout>600</timeout>
</active-response>
<active-response>
  <command>firewall-drop</command>
  <location>local</location>
  <rules_id>100301</rules_id>
  <timeout>600</timeout>
</active-response>
```

Decisión de diseño propia de un ISP: **no se automatiza el bloqueo por fuerza bruta de RADIUS.** La IP que ve el servidor es la del NAS (OLT o router), y bloquearla dejaría sin servicio a todos los abonados detrás de ella. Lo mismo aplica a las IP de abonados con CGNAT: un bloqueo automático puede afectar a muchos clientes. Por eso el bloqueo automático se limita a SSH y al escaneo hacia los servidores de laboratorio, con las redes de administración en lista blanca; en producción el bloqueo de IP de abonados se hace en el NGFW por ticket (ver PB-07). Verificación:

```
sudo iptables -L -n | head
sudo tail -n 20 /var/ossec/logs/active-responses.log
```

4.7 Dashboards

Se crean tres tableros: (1) **Escenarios del caso**, con alertas por regla 100301, 100311, 100320; (2) **Cobertura y salud**, con agentes activos frente al inventario; (3) **Postura**, con SCA y vulnerabilidades por grupo. [Adjunta captura de cada uno, con fecha y hora visibles.]

4.8 Pruebas controladas (solo en el laboratorio)

Escenario	Prueba (entre VM propias)	Resultado esperado	Evidencia
1. Escaneo	`sudo ufw logging medium` en el servidor; desde lnx-atk: `nmap -sS -p 1-200 10.10.20.21`	Reglas 100300, luego 100301 y 100302	Captura de alertas e ID
2a. RADIUS	En el servidor: `for i in $(seq 1 6); do radtest usuario_lab clave_mala 127.0.0.1 0 SECRETO_LAB; done`	Reglas 100310 y 100311	Captura e ID
2b. SSH	Desde lnx-atk, 10 intentos con clave incorrecta a un usuario de laboratorio	Regla 5763 y bloqueo de la IP	`iptables -L` y `active-responses.log`
3. DNS	`sudo sh -c 'echo "; prueba_C11_<INI>" >> /etc/bind/db.conectavalle.example'` y luego revertir	Reglas 550 y 100320 (100322 si es de noche)	Captura con el diff del archivo
FIM base	Crear, modificar y borrar `/etc/prueba_fim_<INICIALES>.txt`	Reglas 554, 550 y 553	Captura

Usa solo usuarios y secretos de laboratorio, nunca los reales. La IP de administración debe estar en la lista blanca para no bloquearte a ti mismo.

5. EDR/XDR Kaspersky

> ***Nota de uso de IA:*** *la redacción de este capítulo (selección de edición, políticas, tareas, exclusiones e integración) se elaboró con ayuda de inteligencia artificial; se declara en el Anexo I.*

5.1 Selección de edición y licencia

Los nombres, alcances y precios de las ediciones cambian por país y fecha. Verifica en la documentación oficial de Kaspersky y con un distribuidor autorizado en Colombia, y registra aquí lo que encuentres.

Criterio	Edición A [nombre]	Edición B [nombre]
Capacidad EDR o XDR	[verificar]	[verificar]
Consola local o en la nube	[verificar]	[verificar]
SO soportados: Windows 11, Server 2022, Linux, macOS	[verificar uno por uno]	[verificar]
Cotización por 20 equipos	[valor de cotización]	[valor de cotización]
Vigencia de la prueba	[fecha de vencimiento]	[fecha de vencimiento]

Criterio de decisión propuesto: elegir la edición que cubra Windows y Linux (los 9 servidores Linux son la mayoría de los activos críticos del ISP) con consola gestionable y que quepa en el OPEX. Evaluar también el riesgo de proveedor que indica la guía: confirmar que no hay restricciones aplicables al caso. Se permite usar la versión de prueba oficial, registrando la fecha de vencimiento.

5.2 Grupos de administración

Grupo	Contenido	Política
Estaciones	5 equipos de atención	Protección completa, control web estricto
Portátiles NOC	3 portátiles	Actualización por Internet, control de USB con lista aprobada
Gerencia macOS	1 equipo	[Según soporte verificado]
Servidores Windows	AD01, FAC02	Control de dispositivos estricto, análisis fuera de horas pico
Servidores Linux	9 servidores	Análisis escalonados; sin análisis completo en horario de pico del DNS y RADIUS
Laboratorio	VM de prueba	Política separada de producción

5.3 Políticas y tareas

Política	Configuración	Motivo en este caso
Protección en tiempo real	Archivos, correo y web activos; desinfectar y, si no se puede, cuarentena	Detiene malware conocido
Control de dispositivos	Bloquear almacenamiento USB con lista aprobada	Evita fuga de datos de abonados. Excepción: adaptadores serial o de consola y USB de firmware de los técnicos del NOC, aprobados con ticket
Control web	Bloquear malware, phishing y anonimizadores	El personal de atención recibe correo de clientes
Firewall del endpoint	Activo, reglas por perfil	Capa extra al NGFW
Exploits y comportamiento	Activados	Detección sin firma
Protección de la configuración	Contraseña para desinstalar o desactivar	Evita que un atacante la apague

Tareas: actualización de bases cada hora, análisis de áreas críticas diario fuera de horario laboral, análisis completo semanal escalonado por grupos, e inventario de software semanal si la edición lo incluye. [Adjunta captura de cada política y tarea.]

5.4 Respuesta N1 y N2

Acción	Analista N1	N2 o responsable
Poner un archivo en cuarentena	Sí, según PB-02	Sí
Aislar un equipo	Solo en severidad Alta o Crítica, según playbook; notifica a N2	Sí, y decide el levantamiento
Aislar un servidor de DNS, RADIUS o facturación	**No.** Escala a N2 y al líder del NOC	Sí, con aprobación del responsable

Terminar un proceso malicioso	Sí, si el playbook lo autoriza	Sí
Modificar políticas o exclusiones	No (propone el cambio)	Sí, con ticket de cambio

Aislar un servidor crítico es una decisión de negocio en un ISP: dejar un DNS o un RADIUS fuera de línea afecta a todos los abonados. Por eso queda reservado a N2.

5.5 Exclusiones

Solo se aplican con impacto demostrado, alcance mínimo, aprobación del responsable del SOC, ticket de cambio y fecha de revisión.

Exclusión candidata	Motivo	Alcance	Aprobó	Revisar
Directorio de datos de la base de datos de facturación	Rendimiento y bloqueos de archivos	Solo SRV-C11-FAC01	Responsable del SOC	3 meses
Logs del agente de seguridad	Evitar bloqueos de lectura	Servidores	Responsable del SOC	3 meses
Repositorio de respaldos	Rendimiento durante la copia	Solo SRV-C11-BCK01, en la ventana del respaldo	Responsable del SOC	3 meses

Nunca se excluyen carpetas de usuario completas, descargas ni unidades enteras. [Elimina las candidatas que no necesites y deja solo las que justifiques con evidencia.]

5.6 Integración con Wazuh por syslog y CEF

En la consola de Kaspersky se configura la exportación al SIEM con protocolo UDP, destino 10.10.90.10 puerto 514 y formato CEF (la ruta exacta depende de la versión). En el manager de Wazuh:

```
<remote>
  <connection>syslog</connection>
  <port>514</port>
  <protocol>udp</protocol>
  <allowed-ips>10.10.90.11</allowed-ips>
  <allowed-ips>10.10.99.0/24</allowed-ips>
</remote>
```

```
sudo systemctl restart wazuh-manager && sudo ss -lunp | grep 514
```

Se activa `logall` solo mientras se obtiene una línea real de CEF, se ajusta el decoder 100200 y 100201 con `wazuh-logtest` y se desactiva `logall` al terminar.

5.7 Verificación

Prueba	Cómo (solo en VM propia, sin carpetas compartidas con el anfitrión)	Resultado esperado
Malware de prueba	Descargar EICAR desde su sitio oficial en la VM Windows	Detección y cuarentena en la consola
Control de dispositivos	Conectar un USB virtual	Bloqueo y evento registrado
Integración con el SIEM	Repetir la detección de EICAR	Alerta en Wazuh con regla 100200 o 100201

Protección de la configuración	Intentar desinstalar el agente sin contraseña	La operación se rechaza

[Adjunta capturas de cada prueba y de la consola con el agente conectado y las bases actualizadas.]

6. GLPI en la nube

> ***Nota de uso de IA:*** *la redacción de este capítulo (diseño, endurecimiento, configuración de la mesa de servicio y respaldo) se elaboró con ayuda de inteligencia artificial; se declara en el Anexo I.*

Versión usada: [GLPI 10.0.x u 11.0.x; verifica en la documentación oficial los requisitos de PHP y MariaDB de la versión elegida]. En ambas, el DocumentRoot de Apache apunta al directorio `public` de GLPI.

6.1 Diseño de la solución

Decisión	Valor	Justificación
Modelo	GLPI autoadministrado en una VM Ubuntu Server LTS	Control total y configuración completa
Proveedor y región	[Proveedor y región más cercana a Colombia]	[Costo, latencia, snapshots, grupos de seguridad]
Tamaño	2 vCPU, 4 GB, 40 GB SSD	10 usuarios, 20 equipos, inventario y base de conocimiento
Red	IP fija; 443 abierto; 80 solo para validar el certificado; 22 solo desde mi IP	Mínimo privilegio
Dominio y certificado	[subdominio propio]; certificado de Let's Encrypt	HTTPS obligatorio. El dominio .example del caso no emite certificados: usa un subdominio propio sin datos reales, o documenta la alternativa y sus límites
Respaldos	Base de datos y archivos diarios, más snapshot del servidor	Ver 6.8
Costo mensual	[Calculadora oficial del proveedor]	Pasa al presupuesto del capítulo 9

La instancia se aloja fuera de la red del ISP a propósito: si la red de ConectaValle cae por un ataque o una falla, la mesa de servicio sigue disponible para gestionar el incidente.

6.2 Endurecimiento

Acceso SSH solo con llave y sin root; UFW con 22 desde la IP de administración, 80 y 443; `fail2ban`; actualizaciones automáticas de seguridad; zona horaria America/Bogota y NTP; certificado con certbot y redirección de HTTP a HTTPS; PHP con `session.cookie_secure` y `session.cookie_httponly`; base de datos con usuario dedicado; eliminación del script de instalación y cambio de las contraseñas por defecto de GLPI. [Adjunta captura de `ufw status`, de la prueba de HTTPS y de la calificación del certificado.]

6.3 Entidades, perfiles y usuarios

Entidad raíz **ConectaValle Telecom** con subentidades NOC, Atención al cliente, Facturación, Infraestructura TI y Gerencia. Logo ficticio y colores propios.

N.º	Usuario ficticio	Rol	Perfil en GLPI
1	Laura Mejía	Gerente general	Supervisor (reportes)
2	Carlos Rueda	Líder del NOC y responsable del SOC	Responsable SOC (administrador)
3	Andrea Quintero	Analista SOC N1-A	Analista SOC N1
4	Julián Prada	Analista SOC N1-B	Analista SOC N1
5	Diego Ardila	Administrador de TI	Técnico
6	Marcela Ortiz	Administradora de redes (N2 interno)	Técnico N2
7	Sofía Cáceres	Jefe de atención al cliente	Self-service
8	Pedro Duarte	Técnico de instalaciones	Self-service
9	Natalia Vargas	Jefe de facturación	Self-service
10	Camilo Rojas	Asesor de atención	Self-service

Todos con correo `usuario@conectavalle.example` y contraseñas fuertes guardadas en el gestor, nunca en el informe. El perfil Analista SOC N1 puede crear y resolver tickets de seguridad y leer el inventario, pero no administra reglas ni usuarios, consistente con el mínimo privilegio.

6.4 Categorías ITIL, prioridad y SLA/OLA

Categorías: **Incidente > Seguridad** (autenticación RADIUS y SSH; reconocimiento y escaneo; cambio de configuración DNS; malware; USB; phishing; cuenta privilegiada; vulnerabilidad), **Incidente > Servicios del ISP** (DNS, RADIUS, DHCP, portal, facturación, enlace), **Solicitud** (autorización de USB, acceso), **Cambio** (ventana de mantenimiento de DNS, cambio de política o exclusión) y **Problema**.

Severidad	Reconocer	Triage	Escalar a N2	Contener o resolver	Cobertura
Crítica	15 min	30 min	≤ 15 min tras confirmar	4 h	24x7 por guardia
Alta	30 min	1 h	≤ 30 min tras confirmar	8 h	Horario laboral y guardia
Media	2 h	4 h	Según el playbook	24 h	Horario laboral
Baja	8 h hábiles	1 día hábil	No aplica	72 h	Horario laboral

Informativa	1 día hábil	No aplica	No aplica	5 días hábiles	Horario laboral

Los mismos tiempos se configuran en GLPI como SLA (tiempo de atención y de resolución) para evitar discrepancias entre el manual y la herramienta. OLA: el N1 entrega la escalación completa al N2 en el tiempo de la tabla; el N2 interno (Marcela Ortiz) acusa recibo en ≤ 30 min en severidad Alta o Crítica. Calendario de GLPI: horario laboral de lunes a viernes y festivos de Colombia.

6.5 Plantilla, reglas de negocio y notificaciones

Plantilla **Alerta de seguridad** con campos obligatorios: origen (Wazuh, Kaspersky, NGFW, usuario), ID de alerta, fecha y hora (America/Bogota), activo afectado, IP de origen y destino, qué ocurrió, enriquecimiento, evidencias, acciones del N1, clasificación (falso positivo, benigno o verdadero positivo) y decisión (cerrar o escalar). Reglas de negocio: los tickets de la categoría Seguridad se asignan al grupo SOC N1 y toman la prioridad según urgencia e impacto; las categorías Crítica y Alta notifican al responsable del SOC. Notificaciones por correo (SMTP 587 con contraseña de aplicación, nunca en el informe) para ticket nuevo, asignación, vencimiento de SLA, solución y cierre. [Adjunta captura de la plantilla, las reglas y un correo recibido.]

6.6 Inventario automático

GLPI Agent en los 20 equipos (Windows, Linux y macOS) con enlace HTTPS a la instancia y etiquetas por VLAN. En el laboratorio se instala en las VM representativas. Cobertura objetivo ≥ 98 % frente al inventario del Anexo A. [Adjunta captura de equipos inventariados.]

6.7 Base de conocimiento (12 artículos)

N.º	Artículo
1 a 9	Los nueve playbooks PB-01 a PB-09 adaptados al caso (capítulo 8)
10	Procedimiento de ventana y ticket de cambio para zonas DNS
11	Cómo solicitar autorización de un USB (técnicos de instalaciones)
12	Cómo reportar un correo sospechoso (atención al cliente)

Reportes y tableros: tickets por categoría, por severidad, cumplimiento de SLA, tiempo medio de resolución y tasa de falsos positivos.

6.8 Respaldo y prueba de restauración

Script diario con volcado de la base de datos y copia de los archivos de GLPI, retención de 7 días y snapshot del servidor (en el repositorio, `04-glpi/backup_glpi.sh`, sin credenciales). Prueba: restaurar en una VM limpia y verificar que el ticket de prueba existe. [Adjunta evidencia de la prueba con fecha y hora.]

6.9 Lista de verificación de la puesta en marcha

- ☐ HTTPS obligatorio y certificado válido
- ☐ Entidades, perfiles y 10 usuarios
- ☐ Categorías, SLA y OLA, y calendario
- ☐ Plantilla y reglas de negocio

- ☐ Notificaciones por correo probadas
- ☐ Inventario con GLPI Agent
- ☐ 12 artículos en la base de conocimiento
- ☐ Reportes
- ☐ Respaldo diario y restauración probada

7. Firewall de nueva generación (NGFW)

> ***Nota de uso de IA:*** *los requisitos, la estructura de la comparación y la redacción de este capítulo se elaboraron con ayuda de inteligencia artificial; los valores de precio provienen únicamente de las cotizaciones reales recibidas; se declara en el Anexo I.*

El NGFW solo se cotiza, no se instala. No se inventan precios: cada valor debe venir de una cotización real recibida por escrito, solicitada identificándote como estudiante en un ejercicio académico sin compromiso de compra.

7.1 Requisitos del caso

Requisito	Valor	Observación
Enlaces a Internet	[X Mbps] con doble proveedor (BGP en routers de borde)	Los routers de borde ya enrutan. El NGFW protege la red interna, la DMZ y la gestión. El tráfico de abonados no atraviesa este equipo.
Usuarios y dispositivos	10 empleados y 20 equipos	
VPN	Acceso remoto para [5] usuarios del NOC; sitio a sitio [sí/no]	
Servicios expuestos	Portal de clientes y facturación en la DMZ	Publicación con IPS
Zonas	6 (oficina, servicios, DMZ, respaldos, seguridad, gestión)	
Alta disponibilidad	[Activo/pasivo sí o no]	Un ISP tolera mal una caída: evaluar el costo
Funciones	IPS, control de aplicaciones, filtrado web, antimalware, inspección SSL/TLS	
Logs	Exportación por syslog o CEF hacia Wazuh	Obligatorio para el SOC

Advertencia de diseño: un NGFW no detiene un DDoS volumétrico: la saturación llega al enlace antes que al equipo. La mitigación real se coordina con los proveedores upstream. El SOC N1 detecta, documenta y escala; no promete mitigación. Dimensiona con el rendimiento con seguridad activa (IPS e inspección SSL) y un margen mínimo del 30 %: [Mbps requeridos × 1,3 = Mbps mínimos].

7.2 Cotizaciones y matriz ponderada

Opciones a cotizar: [Opción A: Fortinet FortiGate, serie y modelo según hoja de datos], [Opción B: Palo Alto Networks, serie PA-400 u otra según hoja de datos], [Opción C: Ruijie u otra equivalente]. Los modelos se eligen en función del rendimiento con seguridad activa que publique cada fabricante. Proveedores: solo socios autorizados verificados en el buscador de socios del fabricante.

Criterio	Peso	Opción A	Opción B	Opción C
Rendimiento con seguridad activa	20 %	[1 a 5]	[1 a 5]	[1 a 5]
Funciones NGFW requeridas	15 %	[ ]	[ ]	[ ]
VPN y conectividad (doble enlace)	10 %	[ ]	[ ]	[ ]
Gestión y facilidad de operación	10 %	[ ]	[ ]	[ ]
Integración y logs (syslog, CEF, API)	10 %	[ ]	[ ]	[ ]
Costo total a 3 años	15 %	[ ]	[ ]	[ ]
Soporte y disponibilidad en Colombia	10 %	[ ]	[ ]	[ ]
Escalabilidad y alta disponibilidad	5 %	[ ]	[ ]	[ ]
Capacitación y comunidad	5 %	[ ]	[ ]	[ ]
Puntaje total	100 %	[calificación × peso]	[ ]	[ ]

Cuadro consolidado (Anexo E): marca y modelo, proveedor y contacto, fecha y vigencia, equipo, suscripciones año 1, renovación años 2 y 3, soporte, instalación y capacitación, IVA, total inicial y TCO a 3 años, todos en COP con la TRM y su fecha. Anexa los tres PDF o correos originales. **Una cotización inventada o alterada anula el componente y se reporta como falta de integridad.**

7.3 Selección y justificación

[Opción elegida y razones técnicas y económicas, riesgos (dependencia de suscripciones), y cómo se relaciona con el tope de CAPEX de COP 70 M. Si el resultado de la matriz no coincide con tu elección, explícalo.] Capacidades de monitoreo exigidas: tráfico permitido y denegado, IPS y antimalware, filtrado web, accesos VPN y cambios de configuración, todos exportables por syslog o CEF.

8. Procesos del SOC N1

> ***Nota de uso de IA:*** *la redacción de los roles, la matriz de severidad, los playbooks, los turnos y los KPI de este capítulo se elaboró con ayuda de inteligencia artificial; se declara en el Anexo I.*

8.1 Roles

Rol	Persona (ficticia)	Responsabilidad
Analista SOC N1	Andrea Quintero y Julián Prada	Monitorea, hace triage, documenta en GLPI, contiene según playbook y escala
Soporte N2	Marcela Ortiz, o un tercero	Investiga y contiene incidentes confirmados

Responsable del SOC	Carlos Rueda	Aprueba procesos, severidades, exclusiones y cambios de reglas
Administrador de TI	Diego Ardila	Ejecuta cambios por ticket aprobado
Gerencia	Laura Mejía	Aprueba presupuesto y decide comunicaciones externas

8.2 Matriz de severidad adaptada al ISP

Severidad	Criterio	Ejemplos en ConectaValle
Crítica	Compromiso confirmado de un activo crítico o impacto inmediato en abonados	Zona DNS alterada sin ticket y con redirección confirmada; RADIUS comprometido; ransomware en facturación
Alta	Actividad maliciosa probable con impacto potencial	Fuerza bruta en RADIUS con login exitoso posterior; cambio DNS sin ticket y sin impacto confirmado; escaneo desde IP interna hacia gestión
Media	Actividad sospechosa que requiere validación	Fuerza bruta bloqueada; USB no autorizado sin copia de datos
Baja	Evento de bajo riesgo o con control compensatorio	Escaneo de abonado bloqueado en el borde
Informativa	Auditoría sin acción	Cambio de DNS aprobado con ticket

8.3 Flujo de triage y acciones permitidas

Recibir, registrar, enriquecer, clasificar, contener, escalar o cerrar, y aprender, con todo registrado en el ticket. El N1 **puede**: poner un archivo en cuarentena, aislar un equipo de usuario en severidad Alta o Crítica, bloquear temporalmente una IP externa en el NGFW, pedir a TI el bloqueo de una cuenta no privilegiada. El N1 **no puede**: borrar evidencias, apagar o aislar servidores de DNS, RADIUS o facturación, tocar cuentas privilegiadas, modificar políticas, exclusiones o reglas sin ticket de cambio, ni hacer forense. Plantilla de escalamiento a N2: ticket y hora, severidad y SLA restante, resumen de 2 o 3 líneas, activos afectados, línea de tiempo, evidencias, acciones del N1, hipótesis con nivel de confianza, solicitud concreta a N2 y contacto del N1.

8.4 Playbooks adaptados (los textos completos están en `06-procesos/playbooks/`)

ID	Alerta	Umbral y activo del caso	Contención N1	Escala a N2 cuando
PB-01	Fuerza bruta SSH o RADIUS (escenario 2)	5 fallos por usuario en 120 s (regla 100311); 15 por NAS en 60 s	Active response solo en SSH; en RADIUS pide el bloqueo en el NGFW por ticket y nunca de un NAS	Hay login correcto posterior (regla 100314), usuario privilegiado o la fuente es interna

		(100312); regla 5763 en SSH		
PB-02	Malware en el EDR	Detección de Kaspersky (100200 o 100201)	Cuarentena; aislar solo equipos de usuario	Se ejecutó, hay propagación o es un servidor
PB-03	Cambio en archivos críticos (escenario 3)	Reglas 100320 o 100322 en `/etc/bind`	No tocar el archivo; verificar ticket de cambio en GLPI	No hay ticket, ocurre fuera de horario, o hay redirección de nombres
PB-04	Inicio de sesión fuera de horario	Accesos al AD o VPN de 7 pm a 6 am	Confirmar con el rol de guardia del NOC antes de tratarlo como anómalo	Cuenta privilegiada o acciones posteriores sensibles
PB-05	USB no autorizado	Evento de control de dispositivos	Pedir retirar el dispositivo	Hubo copia de datos de abonados
PB-06	Phishing reportado	Reporte al buzón de soporte	Bloquear dominio en el NGFW	Se ingresaron credenciales o se ejecutó un adjunto
PB-07	Escaneo de puertos (escenario 1)	Reglas 100301 y 100302	Bloqueo temporal en el NGFW si es externo; si es un abonado, notifica a Atención al cliente y cuidado con CGNAT	El origen es interno o el objetivo es la VLAN 99
PB-08	Cuenta privilegiada nueva	Eventos de cambio de grupo en AD01	Pedir a TI revertir la membresía	Siempre que no haya autorización documentada
PB-09	Vulnerabilidad crítica	CVE crítico o alto en WEB01 u otro servidor	Ticket de gestión con fecha límite	Hay explotación activa y el activo está expuesto

En PB-04, una guardia legítima del NOC en la noche genera falsos positivos: la lista de guardias se mantiene en GLPI y el analista la consulta antes de escalar.

8.5 Turnos y guardias

Franja	Cobertura	Responsable	Alcance
Lunes a viernes 7:00 a 15:00	Monitoreo activo	Analista A	Todas las severidades
Lunes a viernes 11:00 a 19:00	Monitoreo activo con traslape de 4 h	Analista B	Todas las severidades
Noches y madrugadas	Guardia por notificación, apoyada en la guardia del NOC	Guardia rotativa semanal	Crítica y alta; respuesta en 30 min
Fines de semana y festivos	Guardia y revisión del tablero 2 veces al día	Guardia rotativa semanal	Crítica y alta

Relevo de turno: alertas abiertas, tickets pendientes y SLA por vencer, incidentes en curso, cambios programados y falsos positivos conocidos, registrado en un ticket diario. [Verifica la normativa laboral aplicable a turnos y recargos.]

8.6 KPIs

KPI	Fórmula	Fuente	Meta
MTTD	Promedio de (hora de la alerta menos hora de inicio del evento)	Wazuh y Kaspersky	≤ 15 min en Crítica y Alta
MTTA	Promedio de (primera acción menos hora de la alerta)	GLPI	Dentro del SLA en ≥ 90 %
MTTR	Promedio de (contención o cierre menos hora de la alerta)	GLPI	Según severidad
Falsos positivos	Cerradas como falso positivo dividido entre cerradas, por 100	GLPI	Menos de 30 % al tercer mes
Cumplimiento de SLA	Tickets dentro del SLA dividido entre el total, por 100	GLPI	≥ 90 %
Cobertura de agentes	Agentes activos dividido entre equipos del inventario, por 100	Wazuh, Kaspersky y GLPI	≥ 98 %
Vulnerabilidades críticas abiertas	CVE críticos sin remediar por más de 30 días	Wazuh	Cero

Ejemplo: con cinco alertas reconocidas en 10, 20, 5, 40 y 15 minutos, el MTTA es 90 ÷ 5 = 18 minutos. [Reemplaza con los valores medidos en tus tickets.]

8.7 Tickets gestionados (mínimo 6, al menos 3 reales)

N.º	Playbook	Origen	Tipo	Ticket GLPI
1	PB-03 Cambio en DNS (escenario 3)	Wazuh, regla 100320	**Real**, generado en el laboratorio	[N.º]
2	PB-01 Fuerza bruta RADIUS y SSH (escenario 2)	Wazuh, reglas 100311 y 5763	**Real**	[N.º]
3	PB-07 Escaneo de puertos (escenario 1)	Wazuh, reglas 100301 y 100302	**Real**	[N.º]
4	PB-02 Malware EICAR	Kaspersky hacia Wazuh	**Real**	[N.º]
5	PB-08 Cuenta privilegiada nueva	Wazuh sobre AD01	Simulado, indicado expresamente	[N.º]
6	PB-09 Vulnerabilidad crítica	Wazuh	Real si el detector la reportó; si no, simulado	[N.º]

Cada ticket usa la plantilla del Anexo C con triage completo. Los simulados se marcan como tales; presentarlos como reales es una falta de integridad.

9. Presupuesto y cronograma

9.1 Presupuesto

Ningún valor puede ser inventado: cada línea cita su cotización, calculadora oficial o supuesto explícito. Hoja de cálculo con fórmulas incluida en el paquete (`07-presupuesto/Presupuesto_C11.xlsx`). TRM usada: [valor certificado por la Superintendencia Financiera] al [fecha]. IVA: [19 %, verificar vigencia].

Concepto	Tipo	Fuente del valor	Cant.	Valor unitario (COP)	Total (COP)	Frecuencia
Servidor del SIEM (VM o equipo)	CAPEX u OPEX	[Cotización o calculadora]	1	[ ]	[ ]	[ ]
Licencias de Kaspersky (20 equipos)	OPEX	[Cotización del distribuidor]	20	[ ]	[ ]	Anual
NGFW: equipo	CAPEX	Cotización del capítulo 7	1	[ ]	[ ]	Única
NGFW: suscripciones y soporte	OPEX	Cotización del capítulo 7	1	[ ]	[ ]	Anual
GLPI en la nube	OPEX	[Calculadora del proveedor]	1	[ ]	[ ]	Mensual
Dominio y certificados	OPEX	[Proveedor]	1	[ ]	[ ]	Anual
Switches u otro equipo de red para la segmentación	CAPEX	[Cotización]	[ ]	[ ]	[ ]	Única
Implementación (horas del consultor)	CAPEX	Supuesto declarado: [horas × tarifa]	[ ]	[ ]	[ ]	Única
Capacitación	CAPEX	[Cotización o supuesto]	[ ]	[ ]	[ ]	Única
Soporte N2 externo (si aplica)	OPEX	[Cotización]	[ ]	[ ]	[ ]	Mensual
Contingencia 10 % sobre CAPEX	n/a	Cálculo			[ ]	n/a

Indicador	Fórmula	Valor	Tope del caso	¿Cumple?
CAPEX total	Costos únicos más contingencia	[ ]	COP 70.000.000	[Sí o no]
OPEX mensual	OPEX anual ÷ 12	[ ]	COP 5.000.000	[Sí o no]
OPEX anual	Recurrentes × frecuencia	[ ]	COP 60.000.000	[ ]
TCO a 3 años	CAPEX + 3 × OPEX anual	[ ]	Máximo teórico COP 250.000.000	[ ]
Costo mensual por empleado	OPEX mensual ÷ 10	[ ]		
Costo mensual por equipo	OPEX mensual ÷ 20	[ ]		

El tope es de CAPEX y de OPEX mensual por separado: se comparan ambos. Si no cabe, se presenta un escenario básico y uno recomendado y se explica qué se sacrifica (por ejemplo, alta disponibilidad del NGFW o soporte N2 externo). Para un ISP, el rubro que más pesa suele ser el NGFW con sus suscripciones.

9.2 Cronograma de implementación (8 semanas)

Actividad	S1	S2	S3	S4	S5	S6	S7	S8
Alcance, autorización y arquitectura	■							
Instalación y configuración de Wazuh		■						
Despliegue de agentes de Wazuh			■					
Kaspersky: consola y piloto			■	■				
Kaspersky: despliegue a los 20 equipos					■	■		
GLPI en la nube: instalación y configuración					■	■		
NGFW: cotización, compra, entrega e instalación		■	■	■	■	■		
Procesos, playbooks y capacitación						■	■	■
Piloto del SOC N1 con alertas simuladas							■	
Ajustes y puesta en producción								■

El plazo de compra y entrega del NGFW es el factor que más alarga el cronograma. Además, el cambio de segmentación en un ISP se hace en ventana de mantenimiento acordada con el NOC para no afectar a los abonados. Plan de trabajo del parcial (2 semanas): día 1, fases 0 y 1 y envío de solicitudes de cotización; día 2 y 3, Wazuh; día 4 y 5, Kaspersky y Punto de control 1; día 6 y 7, GLPI; día 8 y 9, NGFW, procesos y presupuesto; día 10, informe, repositorio, video y entrega. [Ajusta con lo realmente ejecutado.]

9.3 Matriz RACI

R ejecuta, A aprueba (una sola persona), C consultado, I informado.

Actividad	Gerencia	Líder del proyecto	Analista N1	Admin. de TI	Prov. NGFW	Prov. EDR
Aprobar alcance y autorización	A	R	I	C	-	-
Diseñar arquitectura y segmentación	I	A/R	C	C	C	-
Instalar y configurar Wazuh	I	A	C	R	-	-
Desplegar Kaspersky	I	A	C	R	-	C
Desplegar y configurar GLPI	I	A	C	R	-	-
Comprar e instalar el NGFW	A	R	I	C	R	-
Definir procesos y playbooks	I	A	R	C	-	-
Capacitar al personal	I	A	R	C	C	C
Piloto y puesta en producción	A	R	R	C	I	I

10. Conclusiones

> ***Nota de uso de IA:*** *la redacción de las conclusiones se elaboró con ayuda de inteligencia artificial; se declara en el Anexo I.*

[Completa con tus resultados reales.] Estructura sugerida: (1) qué se logró frente a las metas del capítulo 2, con cifras medidas; (2) qué aprendiste sobre el riesgo particular del ISP (DNS, RADIUS, abonados); (3) limitaciones: el laboratorio es una muestra de 5 VM, el NGFW no se instaló, los tickets simulados se indican como tales, y la compatibilidad con macOS [quedó verificada o solo documentada]; (4) riesgos residuales, entre ellos el DDoS volumétrico que depende del upstream y el punto único de falla del SIEM; (5) trabajo futuro: integración automática Wazuh a GLPI, alta disponibilidad del SIEM, ingesta controlada de logs de DNS y revisión de la retención con la normativa vigente de MinTIC y la CRC.

Referencias

[1] Wazuh Inc., "Wazuh documentation", https://documentation.wazuh.com (consultado el [fecha]). [2] GLPI Project, "GLPI documentation", https://glpi-project.org/documentation/ (consultado el [fecha]). [3] Kaspersky, "Kaspersky technical support and documentation", https://support.kaspersky.com (consultado el [fecha]). [4] Congreso de Colombia, Ley 1273 de 2009. http://www.secretariasenado.gov.co/senado/basedoc/ley_1273_2009.html [5] Congreso de Colombia, Ley 1581 de 2012. http://www.secretariasenado.gov.co/senado/basedoc/ley_1581_2012.html [6] ISO/IEC, ISO/IEC 27001:2022, Information security management systems. https://www.iso.org/standard/27001 [7] NIST, "Cybersecurity Framework 2.0". https://www.nist.gov/cyberframework [8] The FreeRADIUS Project, "FreeRADIUS documentation". https://www.freeradius.org [9] Internet Systems Consortium, "BIND 9 documentation". https://bind9.readthedocs.io [Agrega las cotizaciones del NGFW, la normativa de MinTIC y la CRC que consultes y las hojas de datos de los modelos.]

Anexo D. Informe de incidente (escenario 3: cambio en la zona DNS)

> ***Nota de uso de IA:*** *la plantilla y el texto base de este informe de incidente se elaboraron con ayuda de inteligencia artificial; los datos del incidente deben provenir de la evidencia real del laboratorio; se declara en el Anexo I.*

Se documenta con los datos reales del ticket 1 de la sección 8.7. Estructura obligatoria:

Sección	Contenido para este incidente
1. Identificación	N.º de incidente, ticket de GLPI, fecha y hora de detección, analista, severidad final y estado
2. Resumen ejecutivo	Máximo 5 líneas, sin tecnicismos: qué archivo cambió, si había ticket de cambio, impacto y estado
3. Detección	Regla 100320, host SRV-C11-DNS01-<INI>, hora de la alerta
4. Línea de tiempo	Tabla hora, evento y fuente (cambio, alerta, ticket, verificación, cierre)
5. Activos afectados	Servidor, archivo de zona y servicios dependientes
6. Análisis	Diff del archivo, usuario y proceso, ¿había ticket de cambio?, hipótesis

7. Contención y respuesta	Qué hizo el N1 (sin tocar el archivo) y qué hizo N2, con hora
8. Impacto	Confidencialidad, integridad (alta: se resuelven nombres) y disponibilidad; datos personales, si los hubo
9. Recomendaciones	Procedimiento de cambios para DNS, doble aprobación, ajuste de la regla
10. Lecciones aprendidas	Qué funcionó, qué falló, ajustes de regla
11. Notificaciones	Responsable del SOC y gerencia; si hubo datos personales, evaluar con el responsable la obligación frente a la Ley 1581
12. Anexos	Capturas y extractos de log

Anexo G. Lista de verificación de entrega

- ☐ Fase 0: carta de autorización, inventario (20 equipos) y matriz de riesgos
- ☐ Fase 1: diagramas, VLAN, flujos con puertos, dimensionamiento y retención
- ☐ Fase 2: Wazuh, agentes Windows y Linux, FIM, SCA, vulnerabilidades, 3 o más reglas, active response, dashboards y pruebas
- ☐ Fase 3: Kaspersky con edición justificada, consola, agentes, políticas, tareas, exclusiones, eventos en Wazuh y prueba EICAR
- ☐ Fase 4: GLPI en la nube con HTTPS, configuración completa, respaldo y restauración
- ☐ Fase 5: tres cotizaciones reales con fecha y contacto, matriz y justificación
- ☐ Fase 6: manual del SOC, 9 playbooks, 6 o más tickets (3 reales) e informe de incidente
- ☐ Fase 7: presupuesto con fuentes, TCO, cronograma y RACI
- ☐ Fase 8: informe en PDF, repositorio privado sin secretos y video de 12 a 15 min con una alerta de principio a fin
- ☐ Declaración de uso de IA (Anexo I)
- ☐ Revisión final sin contraseñas, tokens, llaves, IP públicas propias ni datos reales
- ☐ Nombres de archivo: `Parcial_SOC_N1_C11_<Apellido>.pdf` y `Parcial_SOC_N1_C11_<Apellido>_evidencias.zip`

Anexo H. Carta de autorización y reglas de compromiso

> ***Nota de uso de IA:*** *el texto base de esta carta se elaboró con ayuda de inteligencia artificial; se declara en el Anexo I.*

CARTA DE AUTORIZACIÓN Y REGLAS DE COMPROMISO. Implementación de un SOC Nivel 1 (laboratorio académico)

1. **Partes.** El Cliente: ConectaValle Telecom S.A.S. (empresa ficticia), representado para efectos del ejercicio por Julian Barney Jaimes Rincón, en calidad de representante legal ficticio. El Consultor: Camilo Andrés Pérez Carvajal y Sebastián Salón Quintero (en adelante, «el Consultor», entendido en singular para ambos integrantes).
2. **Objeto.** Autorizar al Consultor a diseñar e implementar, en un entorno de laboratorio aislado, un SOC Nivel 1 para el Cliente, que incluye la instalación y configuración de un SIEM, un EDR/XDR, un sistema de tickets e inventario y la cotización de un firewall de nueva generación.

3. **Alcance.** Activos incluidos: máquinas virtuales wazuh-c11-<INI>, ksc-c11-<INI>, win11-c11-<INI>, lnx-svc-c11-<INI>, lnx-atk-c11-<INI> y la instancia glpi-c11-<INI>, en la red virtual aislada 10.10.0.0/16. Activos excluidos: cualquier sistema de terceros, de la institución o de Internet.
4. **Actividades autorizadas.** Instalar y configurar las herramientas en máquinas virtuales propias; generar eventos de prueba controlados (archivo EICAR, modificación de archivos vigilados como la zona DNS de laboratorio, intentos de inicio de sesión fallidos contra RADIUS y SSH de las máquinas propias, y tráfico bloqueado hacia ellas); consultar fuentes públicas de reputación.
5. **Actividades prohibidas.** Escaneos, ataques o pruebas de credenciales contra sistemas fuera del alcance; captura de tráfico ajeno; uso de datos personales reales; desactivación de controles de seguridad de equipos de terceros; divulgación de credenciales o evidencias sensibles.
6. **Ventana de actividades.** Desde [fecha] hasta [fecha].
7. **Confidencialidad y datos.** Los datos del ejercicio son ficticios. Las credenciales y evidencias se manejan como información restringida y no se publican.
8. **Detención y contacto.** Ante un hallazgo real, duda sobre el alcance o impacto inesperado, el Consultor detiene la actividad y contacta a [docente, correo].
9. **Marco legal.** Las partes reconocen la Ley 1273 de 2009 y la Ley 1581 de 2012 y se comprometen a actuar dentro de sus límites.

Anexo I. Declaración de uso de inteligencia artificial

Borrador para que verifiques y corrijas. Solo declara lo que realmente ocurrió y lo que tú verificaste.

Herramienta de IA	Para qué se usó	Qué se verificó o probó	Qué se modificó o rechazó
Claude (Anthropic)	Estructurar el informe y redactar borradores de sus apartados (señalados con «Nota de uso de IA»), reglas y decoders de Wazuh, playbooks, plantillas; ajustes de formato del documento	[Probar cada regla con wazuh-logtest y en el laboratorio; contrastar los comandos con la documentación oficial; reemplazar los marcadores con evidencia propia]	[Lo que cambiaste, ajustaste o descartaste]

- ☐ No usé herramientas de IA en este trabajo.
- ☐ Declaro que lo anterior es completo y que puedo explicar y reproducir todo lo entregado.

Autores: Camilo Andrés Pérez Carvajal y Sebastián Salón Quintero.